

Project 6 — Message Integrity & Replay Protection

Step 1 — Run a Replay Attack on the mTLS Pipeline

Objective

The goal of this task was to demonstrate a replay attack against the existing mTLS-secured MQTT pipeline.

Although mTLS protects the connection by verifying the identity of the connecting device, it does not automatically verify whether an individual message is new or has already been received. In this experiment, I captured legitimate sensor messages and replayed them later to determine whether the subscriber would detect or reject them.

Environment

Project folder:

```
cd "/Users/christinekh/Documents/loT Hydroficient-Extern/Week6/Hydroficient-project"
```

MQTT Broker: Mosquitto

MQTT Port: 8883

Security: Mutual TLS (mTLS)

Device: HYDROLOGIC-Device-001

Topic:

```
hydroficient/grandmarina/device-001/sensors
```

Part 1 — Start the Normal mTLS Pipeline

Step 1.1 — Start the MQTT Broker

In Terminal 1, I navigated to the Week 6 project folder:

```
cd "/Users/christinekh/Documents/loT Hydroficient-Extern/Week6/Hydroficient-project"
```

I then started the Mosquitto broker using the mTLS configuration:

```
mosquitto -c mosquitto_mtls.conf -v
```

The broker started successfully and listened on port **8883**.

Step 1.2 — Start the Subscriber

In Terminal 2, I started the Grand Marina security dashboard:

```
cd "/Users/christinekh/Documents/loT Hydroficient-Extern/Week6/Hydroficient-project"  
python3 subscriber_mtls.py
```

The subscriber successfully connected to the broker using its client certificate.

The terminal displayed:

```
[SUCCESS] Connected to broker as GrandMarina-Dashboard  
[SUBSCRIBED] QoS granted: (1,)
```

This confirmed that the subscriber was successfully connected and listening for MQTT messages.

Step 1.3 — Start the Sensor Publisher

In Terminal 3, I started the HYDROLOGIC sensor publisher:

```
python3 publisher_mtls.py
```

The publisher successfully connected using the device certificate:

[SUCCESS] Connected to broker as HYDROLOGIC-Device-001

[INFO] Certificate identity verified by broker

[PUBLISHING] Sending sensor readings

The publisher sent 8 messages during the test.

The first five readings were:

- 49.0 LPM
- 52.02 LPM
- 46.83 LPM
- 45.88 LPM
- 46.81 LPM

The subscriber displayed these readings normally.

Part 2 — Capture Legitimate Messages

Step 2.1 — Start the Replay Attacker in Capture Mode

In Terminal 4, I started the replay attack tool in capture mode:

```
python3 replay_attacker.py --mode capture --count 5
```

The tool connected to the MQTT broker using mTLS and listened to:

```
hydroficient/grandmarina/#
```

It successfully captured five legitimate messages:

```
[CAPTURED 1/5] HYDROLOGIC-Device-001 - 49.0 LPM
```

```
[CAPTURED 2/5] HYDROLOGIC-Device-001 - 52.02 LPM
```

```
[CAPTURED 3/5] HYDROLOGIC-Device-001 - 46.83 LPM
```

```
[CAPTURED 4/5] HYDROLOGIC-Device-001 - 45.88 LPM
```

```
[CAPTURED 5/5] HYDROLOGIC-Device-001 - 46.81 LPM
```

The tool then saved the captured messages to:

```
captured_messages.json
```

The file was confirmed to exist using:

```
ls -l captured_messages.json
```

The file contained the five captured messages.

Part 3 — Replay the Captured Messages

After the messages had been captured, I restarted the subscriber so that it was listening for the replay.

The subscriber successfully connected again:

```
[SUCCESS] Connected to broker as GrandMarina-Dashboard  
[SUBSCRIBED] QoS granted: (1,)
```

I then ran the replay attack from Terminal 4:

```
python3 replay_attacker.py --mode replay
```

The replay tool loaded the five captured messages:

```
Loaded 5 captured messages
```

It then replayed all five messages.

The tool showed that the original messages had been captured around **09:21–09:22 UTC** and replayed around **09:27 UTC**, meaning they were several minutes old when they were sent again.

The replay tool reported:

[DONE] Replayed 5 messages

[NOTE] Check your subscriber — did it accept them all?

Part 4 — Observe the Subscriber

The subscriber received all five replayed messages and displayed them normally.

For example, the first replayed message contained:

Flow Rate: 49.0 LPM

Pressure (Up): 61.98 PSI

Pressure (Down): 57.51 PSI

Status: operational

The other four replayed messages also matched the original readings.

Importantly, the subscriber did not display any warning, rejection, or indication that these messages were old or had already been received.

The original messages were received around:

12:21:47 – 12:22:07

The replayed messages were displayed around:

12:27:04 – 12:27:08

However, the original timestamps contained inside the messages remained unchanged.

Comparison of Original and Replayed Messages

Message	Original Time	Replay Time	Flow Rate
1	12:21:47	12:27:04	49.0 LPM
2	12:21:52	12:27:05	52.02 LPM
3	12:21:57	12:27:06	46.83 LPM
4	12:22:02	12:27:07	45.88 LPM
5	12:22:07	12:27:08	46.81 LPM

The message contents remained the same during the replay. The main difference was that the messages were received several minutes after they were originally generated.

Results and Questions

1. How many messages were captured?

I captured **5 legitimate messages** from the HYDROLOGIC-Device-001 sensor. The messages were successfully saved to `captured_messages.json` for later replay.

2. How many replayed messages were accepted?

All **5 replayed messages were accepted by the subscriber**. The subscriber processed and displayed each one as a normal sensor reading.

3. Did the subscriber display any warning?

No. The subscriber did not display any warning, rejection, or alert when the old messages were replayed. It processed them exactly like newly received messages.

4. Were the replayed readings identical to the original?

Yes. The replayed messages contained the same device ID, flow rate, upstream and downstream pressure values, status, and original timestamps as the captured messages.

5. Could you tell the difference between real and replayed messages?

No. Based on the subscriber's current output, there was no clear way to distinguish the replayed messages from legitimate new messages. The subscriber did not check whether the timestamp was recent or whether the same message had already been received.

Conclusion

This experiment demonstrated a **replay vulnerability** in the current MQTT pipeline.

The mTLS implementation successfully verifies the identity of the connecting device and protects the MQTT connection with encryption. However, the subscriber currently does not perform message-level validation for freshness or duplicate messages.

As a result, a legitimate message can be captured and sent again later, and the subscriber accepts it as if it were a new reading.

This demonstrates that **mTLS protects the connection and device identity, but it does not by itself provide replay protection for individual messages.**

The next step is to add message-level defenses, including:

1. **Timestamp freshness checks** to detect stale messages.
2. **Sequence counters** to detect duplicate or out-of-order messages.
3. **HMAC signatures** to verify message integrity and detect tampering.

These mechanisms will work together to provide stronger message integrity and replay protection for the Grand Marina water monitoring system.



```
Hydroficient-project — Python subscriber_mtls.py — 80x24

Pressure (Up): 58.48 PSI
Pressure (Down): 54.9 PSI
Status: operational

=====
[RECEIVED] Topic: hydroficient/grandmarina/device-001/sensors
[TIME] 12:27:07
-----
Device: HYDROLOGIC-Device-001
Flow Rate: 45.88 LPM
Pressure (Up): 61.85 PSI
Pressure (Down): 56.54 PSI
Status: operational

=====
[RECEIVED] Topic: hydroficient/grandmarina/device-001/sensors
[TIME] 12:27:08
-----
Device: HYDROLOGIC-Device-001
Flow Rate: 46.81 LPM
Pressure (Up): 58.04 PSI
Pressure (Down): 55.7 PSI
Status: operational

```

```
Hydroficient-project — -zsh — 80x28

[CONNECTING] localhost:8883...

[REPLAYING] Sending captured messages...

[REPLAYING 1/5] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-24T09:21:47.575369Z
Replayed at: 2026-09-24T09:27:04.924484Z

[REPLAYING 2/5] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-24T09:21:52.578170Z
Replayed at: 2026-09-24T09:27:05.930693Z

[REPLAYING 3/5] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-24T09:21:57.583175Z
Replayed at: 2026-09-24T09:27:06.934543Z

[REPLAYING 4/5] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-24T09:22:02.589701Z
Replayed at: 2026-09-24T09:27:07.934877Z

[REPLAYING 5/5] Topic: hydroficient/grandmarina/device-001/sensors
Originally captured: 2026-09-24T09:22:07.592588Z
Replayed at: 2026-09-24T09:27:08.940820Z

[DONE] Replayed 5 messages
[NOTE] Check your subscriber — did it accept them all?
christinekh@christinekhs-MacBook-Pro Hvdroficient-proiect %
```